

Impersonation de token (familia Potato)

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

SelmpersonatePrivilege permite a un proceso actuar con el token de seguridad de otro cliente que se conecte a él. Los exploits de la familia Potato (JuicyPotato, PrintSpoofer, GodPotato) engañan a un servicio privilegiado para que se autentique contra ellos y así capturan y suplantan el token de SYSTEM, obteniendo una shell SYSTEM.

Las cuentas de servicio (IIS, MSSQL) suelen tener Selmpersonate por diseño para funcionar, pero ese mismo privilegio permite robar el token de SYSTEM. Es tan común que ver Selmpersonate en whoami /priv casi garantiza la escalada. Es un caso concreto del winprivesc-modelo.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

En cuanto whoami /priv muestre SelmpersonatePrivilege o SeAssignPrimaryTokenPrivilege como Enabled, típico tras comprometer una web (IIS) o un servicio en Windows.

Cómo identificarla

- SelmpersonatePrivilege = Enabled en whoami /priv.
- Tu usuario es un service account (iis apppool\..., mssql, local service).
- PrintSpoofer o GodPotato devuelven un token de SYSTEM al ejecutarlos.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Ejecuta PrintSpoofer -i -c whoami y comprueba el usuario devuelto.

Evidencia esperada: 'nt authority\system' en la salida de whoami dentro del proceso lanzado.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
PrintSpoofer64.exe -i -c cmd
```

Objetivo y contexto: Abusa de Selpersonate forzando al spooler a autenticarse contra el exploit y suplantando su token SYSTEM. -i abre una consola interactiva como SYSTEM.

Resultado esperado: Un cmd nuevo donde whoami dice 'nt authority\system'. Si falla por version/parcheo del spooler, prueba GodPotato o JuicyPotato segun el Windows.

Anatomía de los payloads

La primera prueba es `PrintSpoofer64.exe -i -c cmd`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

'nt authority\system' en la salida de whoami dentro del proceso lanzado.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Confirma Selpersonate con whoami /priv.
- Sube el binario adecuado (PrintSpoofer/GodPotato segun la version de Windows).
- Ejecutalo pidiendo que lance un comando como SYSTEM (whoami, o tu shell).
- Confirma nt authority\system; con hashes del SAM puedes ademas moverte via ntlm-pth.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- whoami /priv no muestra Selpersonate ni SeAssignPrimaryToken como Enabled.
- El spooler/servicio objetivo esta parcheado contra todas las variantes de Potato conocidas.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

El privilegio Selmpersonate deja suplantar el token de SYSTEM: es la escalada mas comun en cuentas de servicio Windows. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (token-impersonation)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.